

ĐỀ XUẤT ĐỀ TÀI KHÓA LUẬN TỐT NGHIỆP

Ứng dụng Web — Front-end/Back-end: Node.js & React

Ghi chú chung

- Mỗi đề tài đều có tối thiểu 3 vai trò với chức năng phân định rõ ràng, không chồng lấn quyền hạn.
- Mỗi đề tài có tối thiểu 100 use case, được tổ chức theo module chức năng để nhóm dễ phân công theo tuần/sprint.
- Điểm mới của cả 3 đề tài đều nằm ở việc tích hợp AI/LLM theo hướng ứng dụng thực tế, khả thi trong phạm vi khóa luận (8–12 tuần phát triển cho nhóm 5 người).
- Ngăn xếp công nghệ đề xuất: React (Vite) + TailwindCSS cho front-end; Node.js (Express/NestJS) cho back-end; PostgreSQL/MongoDB cho dữ liệu quan hệ/phi quan hệ; có thể dùng thêm Qdrant/pgvector cho các đề tài liên quan RAG.

ĐỀ TÀI 1: Nền tảng Quản lý Rủi ro & An toàn Thông tin Doanh nghiệp tích hợp AI Phát hiện Bất thường

Enterprise Information Security Risk Management Platform with AI-based Anomaly Detection (ISMS/GRC + AI)

1. Mô tả bài toán

Các doanh nghiệp vừa và nhỏ tại Việt Nam thường quản lý rủi ro an toàn thông tin, chính sách tuân thủ và sự cố bảo mật một cách rời rạc qua Excel, email, hoặc các công cụ GRC (Governance, Risk, Compliance) nước ngoài có chi phí cao và không phù hợp quy mô. Đề tài xây dựng một nền tảng web tập trung giúp doanh nghiệp quản lý tài sản CNTT, đánh giá rủi ro theo khung chuẩn (ISO 27001/NIST), quản lý chính sách, xử lý sự cố và đào tạo nhận thức an toàn thông tin.

Điểm nhấn của hệ thống là phân hệ AI giám sát log/hành vi để tự động phát hiện các bất thường (đăng nhập lạ, truy cập trái phép, hành vi rời quy chuẩn), từ đó đề xuất mức độ rủi ro và hỗ trợ đội ATTT phản ứng nhanh hơn thay vì rà soát log thủ công.

2. Tính mới so với các hệ thống hiện có

- Kết hợp GRC (quản lý rủi ro/tuân thủ) và phát hiện bất thường bằng AI trong cùng một nền tảng — các công cụ GRC hiện tại (ví dụ Eramba, các bộ Excel GRC) thường không tích hợp AI, còn các SIEM/AI phát hiện bất thường (Splunk, Wazuh) lại không có phân hệ quản lý rủi ro/tuân thủ đầy đủ dành cho doanh nghiệp vừa và nhỏ.
- Cơ chế explainable AI: mỗi cảnh báo AI đều kèm giải trình (dựa trên đặc trưng hành vi nào mô hình đưa ra kết luận), giúp chuyên viên ATTT không phải 'tin mù' vào AI — khác với phần lớn hệ thống thương mại chỉ trả về điểm số rủi ro.
- Vòng phản hồi (feedback loop): chuyên viên đánh dấu cảnh báo đúng/sai để tinh chỉnh mô hình theo đặc thù tổ chức, giúp giảm dần tỷ lệ cảnh báo giả theo thời gian sử dụng — cá nhân hóa mô hình theo từng doanh nghiệp thay vì dùng chung một mô hình tổng quát.
- Tự động sinh bản nháp hồ sơ sự cố ngay từ cảnh báo AI, rút ngắn thời gian từ phát hiện đến ghi nhận sự cố chính thức.

3. Công nghệ đề xuất

- Front-end: ReactJS, TailwindCSS, Recharts/D3 cho trực quan hóa dashboard rủi ro.
- Back-end: Node.js (NestJS/Express), REST API, WebSocket cho cảnh báo real-time.
- AI/ML: mô hình phát hiện bất thường (Isolation Forest/Autoencoder) hoặc kết nối LLM cục bộ (Ollama) để phân tích log ngôn ngữ tự nhiên.
- Cơ sở dữ liệu: PostgreSQL (dữ liệu nghiệp vụ) + Elasticsearch/OpenSearch (lưu trữ, tìm kiếm log).

4. Danh sách vai trò

Vai trò	Mô tả chức năng chính
Quản trị viên hệ thống (Admin)	Quản lý tài khoản, phân quyền, cấu hình hệ thống, tích hợp, giám sát nhật ký toàn hệ thống.
Chuyên viên ATTT / Quản lý rủi ro (Security Officer)	Quản lý tài sản, thực hiện đánh giá rủi ro, xử lý sự cố, cấu hình và xử lý cảnh báo AI, soạn thảo chính sách.
Nhân viên đơn vị nghiệp vụ (Employee)	Báo cáo sự cố, xác nhận đọc chính sách, tham gia đào tạo nhận thức, cung cấp thông tin tài sản do mình phụ trách.
Ban lãnh đạo / Kiểm toán viên (Executive/Auditor)	Phê duyệt kế hoạch xử lý rủi ro, xem báo cáo tổng hợp, dashboard điều hành, đối chiếu bằng chứng tuân thủ.

5. Gợi ý phân công 5 thành viên nhóm

- SV1: Module Xác thực, Người dùng & Phân quyền, Thông báo/Nhật ký.

- SV2: Module Tài sản CNTT, Đánh giá rủi ro.
- SV3: Module Chính sách/Tuân thủ, Sự cố, Đào tạo nhận thức.
- SV4: Module AI phát hiện bất thường (huấn luyện mô hình, tích hợp API AI vào back-end).
- SV5: Module Báo cáo/Dashboard, Workflow phê duyệt, Tích hợp API bên thứ ba, kiểm thử tổng thể.

6. Danh sách Use Case chi tiết theo module (tổng cộng: 101 use case)

Bảng dưới đây liệt kê toàn bộ use case theo từng module chức năng, kèm vai trò thực hiện tương ứng.

STT	Module / Chức năng	Use Case	Vai trò thực hiện
1	Xác thực & Tài khoản	Đăng ký/khởi tạo tài khoản người dùng mới	Admin
2	Xác thực & Tài khoản	Đăng nhập hệ thống	Tất cả vai trò
3	Xác thực & Tài khoản	Đăng xuất hệ thống	Tất cả vai trò
4	Xác thực & Tài khoản	Quên mật khẩu / đặt lại mật khẩu	Tất cả vai trò
5	Xác thực & Tài khoản	Đổi mật khẩu cá nhân	Tất cả vai trò
6	Xác thực & Tài khoản	Bật/xác thực đa yếu tố (MFA)	Tất cả vai trò
7	Xác thực & Tài khoản	Khóa/mở khóa tài khoản người dùng	Admin
8	Xác thực & Tài khoản	Xem lịch sử đăng nhập của tài khoản	Admin, Security Officer
9	Quản lý người dùng & phân quyền	Thêm người dùng mới vào hệ thống	Admin
10	Quản lý người dùng & phân quyền	Sửa thông tin người dùng	Admin
11	Quản lý người dùng & phân quyền	Vô hiệu hóa/xóa người dùng	Admin
12	Quản lý người dùng & phân quyền	Gán vai trò cho người dùng	Admin
13	Quản lý người dùng & phân quyền	Tạo vai trò tùy chỉnh (custom role)	Admin
14	Quản lý người dùng & phân quyền	Cấu hình phân quyền chi tiết theo module	Admin
15	Quản lý người dùng & phân quyền	Xem danh sách người dùng theo phòng ban	Admin
16	Quản lý người dùng & phân quyền	Nhập danh sách người dùng hàng loạt từ Excel	Admin
17	Quản lý tài sản CNTT (Asset)	Thêm mới tài sản CNTT	Security Officer
18	Quản lý tài sản CNTT (Asset)	Sửa thông tin tài sản	Security Officer
19	Quản lý tài sản CNTT (Asset)	Xóa/ngừng theo dõi tài sản	Security Officer
20	Quản lý tài sản CNTT (Asset)	Xem danh sách tài sản	Security Officer, Employee, Executive
21	Quản lý tài sản CNTT (Asset)	Tìm kiếm, lọc tài sản theo tiêu chí	Security Officer
22	Quản lý tài sản CNTT (Asset)	Phân loại tài sản theo mức độ quan trọng	Security Officer
23	Quản lý tài sản CNTT (Asset)	Gán chủ sở hữu (owner) cho tài sản	Security Officer
24	Quản lý tài sản CNTT (Asset)	Nhập danh sách tài sản hàng loạt (import Excel)	Security Officer
25	Quản lý tài sản CNTT (Asset)	Xuất danh sách tài sản ra file	Security Officer, Executive
26	Quản lý tài sản CNTT (Asset)	Xem lịch sử thay đổi thông tin tài sản	Security Officer, Admin
27	Đánh giá rủi ro (Risk Assessment)	Tạo phiên đánh giá rủi ro cho tài sản/quy trình	Security Officer
28	Đánh giá rủi ro (Risk Assessment)	Xác định mối đe dọa (threat) liên quan	Security Officer
29	Đánh giá rủi ro (Risk Assessment)	Xác định lỗ hổng (vulnerability) liên quan	Security Officer
30	Đánh giá rủi ro (Risk Assessment)	Tính điểm rủi ro tự động (khả năng x mức ảnh hưởng)	Security Officer
31	Đánh giá rủi ro (Risk Assessment)	Đề xuất biện pháp xử lý rủi ro	Security Officer
32	Đánh giá rủi ro (Risk Assessment)	Gửi kế hoạch xử lý rủi ro chờ phê duyệt	Security Officer
33	Đánh giá rủi ro (Risk Assessment)	Phê duyệt kế hoạch xử lý rủi ro	Executive
34	Đánh giá rủi ro (Risk Assessment)	Từ chối/yêu cầu chỉnh sửa đánh giá rủi ro	Executive
35	Đánh giá rủi ro (Risk Assessment)	Theo dõi tiến độ xử lý rủi ro	Security Officer, Executive
36	Đánh giá rủi ro (Risk Assessment)	Đóng rủi ro sau khi đã xử lý	Security Officer
37	Đánh giá rủi ro (Risk Assessment)	Xem ma trận nhiệt rủi ro (risk heat map)	Security Officer, Executive

STT	Module / Chức năng	Use Case	Vai trò thực hiện
38	Đánh giá rủi ro (Risk Assessment)	So sánh biến động rủi ro giữa các kỳ đánh giá	Executive
39	Chính sách & Kiểm soát tuân thủ	Soạn thảo chính sách an toàn thông tin	Security Officer
40	Chính sách & Kiểm soát tuân thủ	Ban hành phiên bản chính sách chính thức	Admin
41	Chính sách & Kiểm soát tuân thủ	Cập nhật, tạo phiên bản mới cho chính sách	Security Officer
42	Chính sách & Kiểm soát tuân thủ	Gán chính sách áp dụng cho đơn vị/phòng ban	Security Officer
43	Chính sách & Kiểm soát tuân thủ	Xác nhận đã đọc và hiểu chính sách	Employee
44	Chính sách & Kiểm soát tuân thủ	Ánh xạ kiểm soát theo khung chuẩn (ISO 27001/NIST)	Security Officer
45	Chính sách & Kiểm soát tuân thủ	Đánh giá mức độ tuân thủ từng kiểm soát	Security Officer
46	Chính sách & Kiểm soát tuân thủ	Tải lên bằng chứng tuân thủ (evidence)	Security Officer, Employee
47	Chính sách & Kiểm soát tuân thủ	Xem lịch sử các phiên bản chính sách	Tất cả vai trò
48	Chính sách & Kiểm soát tuân thủ	Nhận nhắc nhở tuân thủ tự động theo hạn	Employee, Security Officer
49	Quản lý sự cố an toàn thông tin	Ghi nhận/báo cáo sự cố mới	Employee, Security Officer
50	Quản lý sự cố an toàn thông tin	Phân loại mức độ nghiêm trọng của sự cố	Security Officer
51	Quản lý sự cố an toàn thông tin	Gán người/nhóm xử lý sự cố	Security Officer
52	Quản lý sự cố an toàn thông tin	Cập nhật tiến trình xử lý sự cố	Security Officer
53	Quản lý sự cố an toàn thông tin	Đính kèm bằng chứng, log liên quan sự cố	Security Officer
54	Quản lý sự cố an toàn thông tin	Leo thang sự cố nghiêm trọng lên ban lãnh đạo	Security Officer
55	Quản lý sự cố an toàn thông tin	Đóng sự cố sau khi xử lý xong	Security Officer
56	Quản lý sự cố an toàn thông tin	Lập báo cáo hậu sự cố (post-incident report)	Security Officer
57	Quản lý sự cố an toàn thông tin	Xem lịch sử sự cố đã xử lý	Security Officer, Executive
58	Quản lý sự cố an toàn thông tin	Liên kết sự cố với rủi ro đã đánh giá liên quan	Security Officer
59	AI phát hiện bất thường & cảnh báo (điểm mới)	Cấu hình nguồn log/dữ liệu để AI phân tích	Admin, Security Officer
60	AI phát hiện bất thường & cảnh báo (điểm mới)	Tinh chỉnh mô hình phát hiện bất thường theo hành vi tổ chức	Security Officer
61	AI phát hiện bất thường & cảnh báo (điểm mới)	Xem danh sách cảnh báo AI theo thời gian thực	Security Officer
62	AI phát hiện bất thường & cảnh báo (điểm mới)	Đánh giá độ tin cậy của cảnh báo (feedback loop)	Security Officer
63	AI phát hiện bất thường & cảnh báo (điểm mới)	Xác nhận cảnh báo AI là sự cố thật	Security Officer
64	AI phát hiện bất thường & cảnh báo (điểm mới)	Đánh dấu cảnh báo sai (false positive) để huấn luyện lại mô hình	Security Officer
65	AI phát hiện bất thường & cảnh báo (điểm mới)	Xem đề xuất mức độ rủi ro do AI tính toán	Security Officer
66	AI phát hiện bất thường & cảnh báo (điểm mới)	Xem giải thích quyết định của AI (explainable AI)	Security Officer, Executive
67	AI phát hiện bất thường & cảnh báo (điểm mới)	Tự động tạo bản nháp hồ sơ sự cố từ cảnh báo AI	Security Officer
68	AI phát hiện bất thường & cảnh báo (điểm mới)	Thiết lập ngưỡng cảnh báo tùy chỉnh theo tài sản	Security Officer
69	Đào tạo nhận thức an toàn thông tin	Tạo khóa đào tạo/nội dung nhận thức ATTT	Security Officer
70	Đào tạo nhận thức an toàn thông tin	Gán khóa đào tạo cho nhân viên/phòng ban	Security Officer
71	Đào tạo nhận thức an toàn thông tin	Làm bài kiểm tra nhận thức sau đào tạo	Employee

STT	Module / Chức năng	Use Case	Vai trò thực hiện
72	Đào tạo nhận thức an toàn thông tin	Theo dõi tiến độ hoàn thành đào tạo	Security Officer, Executive
73	Đào tạo nhận thức an toàn thông tin	Gửi nhắc nhở hoàn thành đào tạo còn hạn	Employee
74	Đào tạo nhận thức an toàn thông tin	Cấp chứng nhận hoàn thành khóa đào tạo	Security Officer
75	Đào tạo nhận thức an toàn thông tin	Xem báo cáo tỷ lệ hoàn thành theo phòng ban	Executive
76	Báo cáo & Dashboard	Xem dashboard tổng quan rủi ro/sự cố thời gian thực	Tất cả vai trò
77	Báo cáo & Dashboard	Xuất báo cáo rủi ro định kỳ (PDF/Excel)	Security Officer
78	Báo cáo & Dashboard	Xuất báo cáo mức độ tuân thủ theo khung chuẩn	Security Officer
79	Báo cáo & Dashboard	Tùy chỉnh widget dashboard theo vai trò	Tất cả vai trò
80	Báo cáo & Dashboard	So sánh chỉ số ATTT giữa các kỳ báo cáo	Executive
81	Báo cáo & Dashboard	Lập báo cáo KPI an toàn thông tin	Security Officer
82	Báo cáo & Dashboard	Xem báo cáo tóm tắt dành cho ban lãnh đạo	Executive
83	Báo cáo & Dashboard	Lên lịch gửi báo cáo tự động qua email	Security Officer, Admin
84	Thông báo & Nhật ký hệ thống	Gửi thông báo trong hệ thống	Admin
85	Thông báo & Nhật ký hệ thống	Gửi thông báo qua email	Admin
86	Thông báo & Nhật ký hệ thống	Cấu hình kênh nhận thông báo cá nhân	Tất cả vai trò
87	Thông báo & Nhật ký hệ thống	Xem nhật ký hoạt động người dùng (audit log)	Admin
88	Thông báo & Nhật ký hệ thống	Tìm kiếm nhật ký theo bộ lọc nâng cao	Admin, Security Officer
89	Thông báo & Nhật ký hệ thống	Xuất nhật ký phục vụ điều tra	Admin
90	Thông báo & Nhật ký hệ thống	Xem lịch sử thay đổi cấu hình hệ thống	Admin
91	Phê duyệt & Quy trình (Workflow)	Thiết lập quy trình phê duyệt tùy chỉnh	Admin
92	Phê duyệt & Quy trình (Workflow)	Phê duyệt/từ chối yêu cầu trong hệ thống	Executive, Security Officer
93	Phê duyệt & Quy trình (Workflow)	Ủy quyền phê duyệt tạm thời khi vắng mặt	Executive
94	Phê duyệt & Quy trình (Workflow)	Theo dõi trạng thái yêu cầu đang chờ xử lý	Tất cả vai trò
95	Phê duyệt & Quy trình (Workflow)	Nhận nhắc nhở khi yêu cầu phê duyệt quá hạn	Executive
96	Phê duyệt & Quy trình (Workflow)	Xem lịch sử các quyết định phê duyệt	Admin, Executive
97	Tích hợp & API	Kết nối API với hệ thống SIEM/tường lửa bên thứ ba	Admin
98	Tích hợp & API	Đồng bộ log tự động theo lịch trình	Admin
99	Tích hợp & API	Quản lý API key cho các tích hợp	Admin
100	Tích hợp & API	Theo dõi trạng thái kết nối tích hợp	Admin
101	Tích hợp & API	Xem log lỗi trong quá trình đồng bộ dữ liệu	Admin